

Containment Strategies & Recovery

Containment Levels (Pick by Situation)

Technique	When	Consequence
Isolate host (unplug / V-LAN cut)	single host, low spread	host offline; last-resort data risk
Block C2 at firewall/EDR	attacker is beaconing out	may tip off attacker
Account lockout/reset	attacker using stolen creds	disrupts user too (coordinate)
Segment / micro-segment	broad spread, don't cut everything	keeps business running
Kill switch (DNS sinkhole, trademark alert)	influential malware	attacker changes infra

The ranking question: what's the *fastest brake* that *keeps the important systems alive* and *protects evidence most*?

The "Don't Reboot First" Rule

If you think it's an incident:

Collect **memory** and **evidence** BEFORE power actions (reboot wipes memory!)

Only then isolate / power off if indicated

Unless it's spreading **right now** – then containment beats forensics, and you document that call.

Eradication: Complete or Done

Incomplete eradication = the #1 cause of re-compromise:

Find ALL the footholds (not just the first one): persistence, backup accounts, sockets

Reset credentials EVERYWHERE (all accounts touched by the attacker's path + services)

Patch the ROOT CAUSE vuln

Verify: no new beaconing, no unknown users, no open holes

Recovery: The Re-Entry Watch

The classic horror: restored from backup, and 3 weeks later the same attacker is back – because *the backup itself* had a dormant backdoor.

Hard rules:

Restore points cleaned before the infection window (find first-sign from logs)

Validate restored state (AV scan, tripwire file check)

Monitor restored systems with extra vigilance for a defined period

Gradual reconnection – don't slam everything back on the unfiltered network at once

The Business Conversation

IR recovery is a *business continuity* problem, not just technical:

What can wait vs what must run now

Managed downtime beats unplanned outage

Executive communication: 1-page status (facts, systems, status, next)

Legal/PR trigger points pre-defined

The recovery metric: not "services are back" but "we are back *and* we know the attacker isn't." Re-entry is the silent failure.

← Playbooks & Confirmed Incide...

Lessons Learned & Root Cause A...